

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE CODE: CSA5110 COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO3: *Examine cryptographic hash algorithms, digital signature schemes, and assess Kerberos and X.509 authentication frameworks for ensuring integrity, authentication, and non-repudiation.* CO (BL4 , BL5)

Assessment Tool Weightage: 20%

QUESTIONS: 5

TOTAL MARKS: 25

Annexure A CASE STUDY

Code of Conduct:

I SAIRAM D 192424111 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

3. Kerberos Replay Attack in an Enterprise Network

Case Study

An enterprise network uses Kerberos for authentication. Kerberos provides secure authentication by using tickets and a trusted Key Distribution Center (KDC). However, an attacker may perform a replay attack if a valid authentication message or ticket is captured and reused later.

How the Attack Could Occur

In a replay attack, the attacker first monitors the network and captures a valid authentication message sent between a client and server. If the captured message can be reused within its valid time period, the attacker may send the same message to the server.

For example:

- A legitimate user authenticates using Kerberos.
- The user receives a Kerberos ticket or authenticator.
- An attacker captures the authentication message from the network.
- The attacker sends the captured message again to the server.
- If the server does not properly detect that the message has already been used, it may accept the replayed authentication.
- The attacker can then gain unauthorized access to the protected service.

Weakness

The main weakness is improper protection against the reuse of previously captured authentication information. Although Kerberos already provides mechanisms such as timestamps and session keys, poor configuration, excessive ticket lifetime, clock synchronization problems, or inadequate replay detection can increase the risk.

Enhancements to Prevent Replay Attacks

The following security measures can be implemented:

Use timestamps: Kerberos authenticators should contain timestamps so that old messages are rejected.

Use short ticket lifetimes: Reduce the time for which authentication tickets remain valid.

Replay cache: Servers should maintain a replay cache to detect previously used authenticators.

Strong encryption: Use modern and secure encryption algorithms for tickets and authentication messages.

Session keys: Use unique session keys for secure communication between the client and server.

Clock synchronization: Keep client and server clocks synchronized so that timestamp validation works correctly.

Secure the KDC: The Key Distribution Center should be strongly protected because it is a trusted component of Kerberos.

Monitor authentication logs: Repeated or suspicious authentication attempts should be detected and investigated.

Conclusion

Kerberos is a strong authentication system, but replay attacks can occur if authentication messages are not properly protected and validated. Using timestamps, replay caches, short ticket lifetimes, strong encryption, synchronized clocks, and proper monitoring can significantly reduce the possibility of replay attacks.

10. Multi-Factor Authentication for Online Banking

Case Study

An online banking system uses only a username and password for authentication. Attackers obtain customer credentials through phishing and use them to access bank accounts. This shows that password-only authentication is not sufficient for protecting sensitive banking information.

Weaknesses of Password-Only Authentication

Username and password authentication has several weaknesses:

- Phishing: Attackers can create fake websites or messages to trick users into revealing their passwords.
- Password reuse: Users may use the same password on multiple websites. If one website is compromised, attackers can try the same password on the banking account.
- Brute-force attacks: Weak passwords can be guessed using automated attacks.
- Credential theft: Passwords can be stolen through malware, keyloggers, or data breaches.
- No additional verification: Once an attacker obtains the password, there is no second security check.

Therefore, a stolen password can directly result in unauthorized account access.

Proposed Multi-Factor Authentication Mechanism

The banking system should implement Multi-Factor Authentication (MFA). MFA requires at least two different authentication factors.

A suitable banking authentication process is:

Step 1 – Username and Password

The customer enters their username and password.

Step 2 – OTP Verification

After successful password verification, the bank generates a short-lived One-Time Password (OTP). The OTP can be generated using a secure authenticator application or another trusted second factor.

Step 3 – Cryptographic Verification

The system can use a cryptographic mechanism such as a digital signature or public-key authentication. The customer's private key remains securely stored on the registered device, while the bank stores the corresponding public key.

The user signs an authentication challenge with the private key. The bank verifies the signature using the public key.

Step 4 – Access Granted

Only when the password and second authentication factor are successfully verified is access to the banking account granted.

Example Authentication Flow

User → Username + Password → Bank Server

↓

Password Verified

↓

OTP / Cryptographic Challenge

↓

OTP Verified / Digital Signature Verified

↓

Access Granted

Security Benefits

- OTP: A stolen password alone is not enough because the attacker also needs the temporary OTP.
- Digital certificates: They provide strong cryptographic authentication and make impersonation more difficult.
- Digital signatures: The private key can remain securely on the user's registered device and is not directly sent to the bank.
- Short-lived authentication codes: Even if an OTP is captured, its limited validity reduces the attack window.
- Multiple factors: Compromise of one authentication factor does not automatically compromise the account.

Conclusion

Password-only authentication is vulnerable to phishing, password theft, brute-force attacks, and credential reuse. A combination of password + OTP + cryptographic authentication, such as digital certificates or digital signatures, provides much stronger protection. Therefore, MFA should be used in online banking to prevent unauthorized access even when a user's password has been compromised.